INSTALACIÓN LABORATORIO DVWA

1. Objetivo del laboratorio

El objetivo del laboratorio es **practicar auditorías de seguridad web** en un entorno controlado.
DVWA es una aplicación PHP/MySQL intencionadamente vulnerable que permite trabajar con:

- Inyección SQL
- XSS
- CSRF
- File upload
- Command injection
- Fuerza bruta
- Seguridad en login
- Validación de entrada

⚙️ 2. Instalación de DVWA en Kali Linux

🔹 Paso 1. Instalar Apache, PHP y MySQL

sudo apt update

sudo apt install apache2 mariadb-server php php-mysqli php-gd libapache2-mod-php -y

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ sudo apt update
[sudo] password for kali:
Hit:1 https://repo.protonvpn.com/debian stable InRelease
Get:2 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB
Get:4 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [5

Get:5 http://kali.download/kali kali-rolling/contrib amd64 Packages [115
Get:6 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)
kB]
Fetched 73.2 MB in 14s (5,238 kB/s)
45 packages can be upgraded. Run 'apt list --upgradable' to see them.

┌──(kali㉿kali)-[~]
└─$ sudo apt full-upgrade -y
The following packages were automatically installed and are no longer req
  amass-common              libtheora0
  firmware-ti-connectivity  libtheoradec1
  libbluray2                libtheoraenc1
  libbson-1.0-0t64          libudfread0
  libgdal36                 libvpx9
```

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install apache2 mariadb-server php php-mysqli php-gd libapache
d-php -y

[sudo] password for kali:
Note, selecting 'php8.4-mysql' instead of 'php-mysqli'
apache2 is already the newest version (2.4.65-3+b1).
mariadb-server is already the newest version (1:11.8.3-1+b1).
mariadb-server set to manually installed.
php is already the newest version (2:8.4+96).
php set to manually installed.
php8.4-mysql is already the newest version (8.4.11-1+b1).
```

- **Paso 2. Clonar el repositorio de DVWA**

cd /var/www/html

sudo git clone https://github.com/digininja/DVWA.git

```
┌──(kali㉿kali)-[~]
└─$ cd /var/www/html

┌──(kali㉿kali)-[/var/www/html]
└─$ sudo git clone https://github.com/digininja/DVWA.git
Cloning into 'DVWA' ...
remote: Enumerating objects: 5595, done.
remote: Counting objects: 100% (66/66), done.
remote: Compressing objects: 100% (31/31), done.
remote: Total 5595 (delta 50), reused 37 (delta 35), pack-reused 5529 (fr
Receiving objects: 100% (5595/5595), 2.64 MiB | 3.27 MiB/s, done.
Resolving deltas: 100% (2781/2781), done.
```

- **Paso 3. Asignar permisos adecuados**

sudo chown -R www-data:www-data /var/www/html/DVWA

sudo chmod -R 755 /var/www/html/DVWA

```
┌──(kali㉿kali)-[/var/www/html]
└─$ sudo chown -R www-data:www-data /var/www/html/DVWA

┌──(kali㉿kali)-[/var/www/html]
└─$ sudo chmod -R 755 /var/www/html/DVWA
```

- **Paso 4. Configurar la base de datos**

sudo mysql

Dentro del cliente MySQL:

CREATE DATABASE dvwa;

CREATE USER 'dvwauser'@'localhost' IDENTIFIED BY 'dvwapass';

GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwauser'@'localhost';

FLUSH PRIVILEGES;

EXIT;

```
┌──(kali㉿kali)-[/var/www/html]
└─$ sudo mariadb
ERROR 2002 (HY000): Can't connect to local serv
ysqld.sock' (2)

┌──(kali㉿kali)-[/var/www/html]
└─$ sudo systemctl start mariadb

┌──(kali㉿kali)-[/var/www/html]
└─$ sudo mariadb
```

```
┌──(kali㉿kali)-[/var/www/html]
└─$ sudo mariadb
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.3-MariaDB-1+b1 from Debian -- Please help get to 10k
 at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input state

MariaDB [(none)]> CREATE DATABASE dvwa;
Query OK, 1 row affected (0.000 sec)

MariaDB [(none)]> CREATE USER 'dvwauser'@'localhost' IDENTIFIED BY 'dvwap
Query OK, 0 rows affected (0.015 sec)

MariaDB [(none)]> GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwauser'@'localhost
```

- **Paso 5. Editar el archivo de configuración**

cd /var/www/html/DVWA/config

sudo cp config.inc.php.dist config.inc.php

sudo nano config.inc.php

Modifica las siguientes líneas:

$_DVWA['db_user'] = 'dvwauser';

$_DVWA['db_password'] = 'dvwapass';

$_DVWA['db_database'] = 'dvwa';

```
┌──(kali㉿kali)-[/var/www/html]
└─$ cd /var/www/html/DVWA/config

┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$ sudo cp config.inc.php.dist config.inc.php

┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$ sudo nano config.inc.php

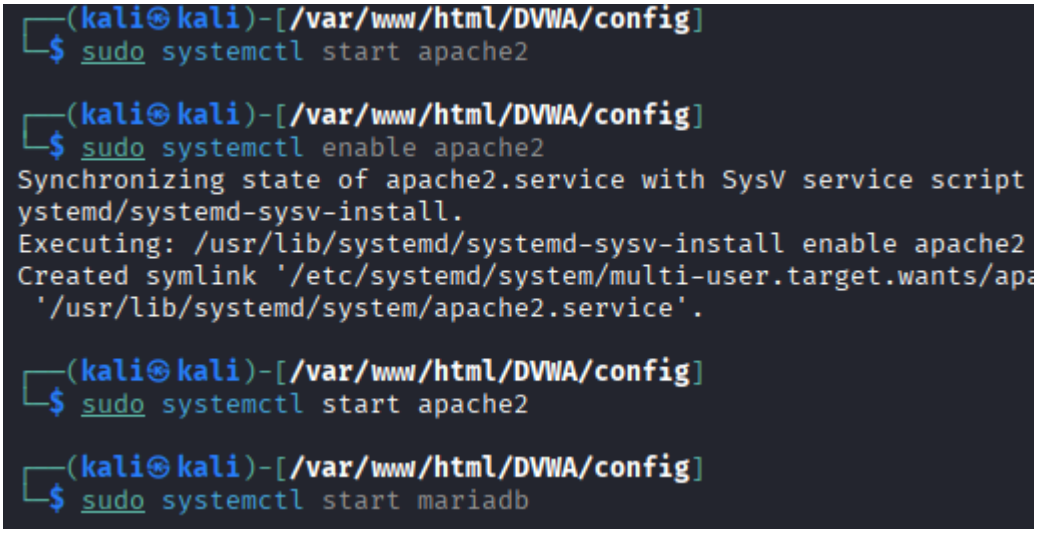
┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$
```

- **Paso 6. Activar el servidor y reiniciar servicios**

sudo systemctl start apache2

sudo systemctl enable apache2

sudo systemctl start mariadb



- **Paso 7. Acceder a DVWA**

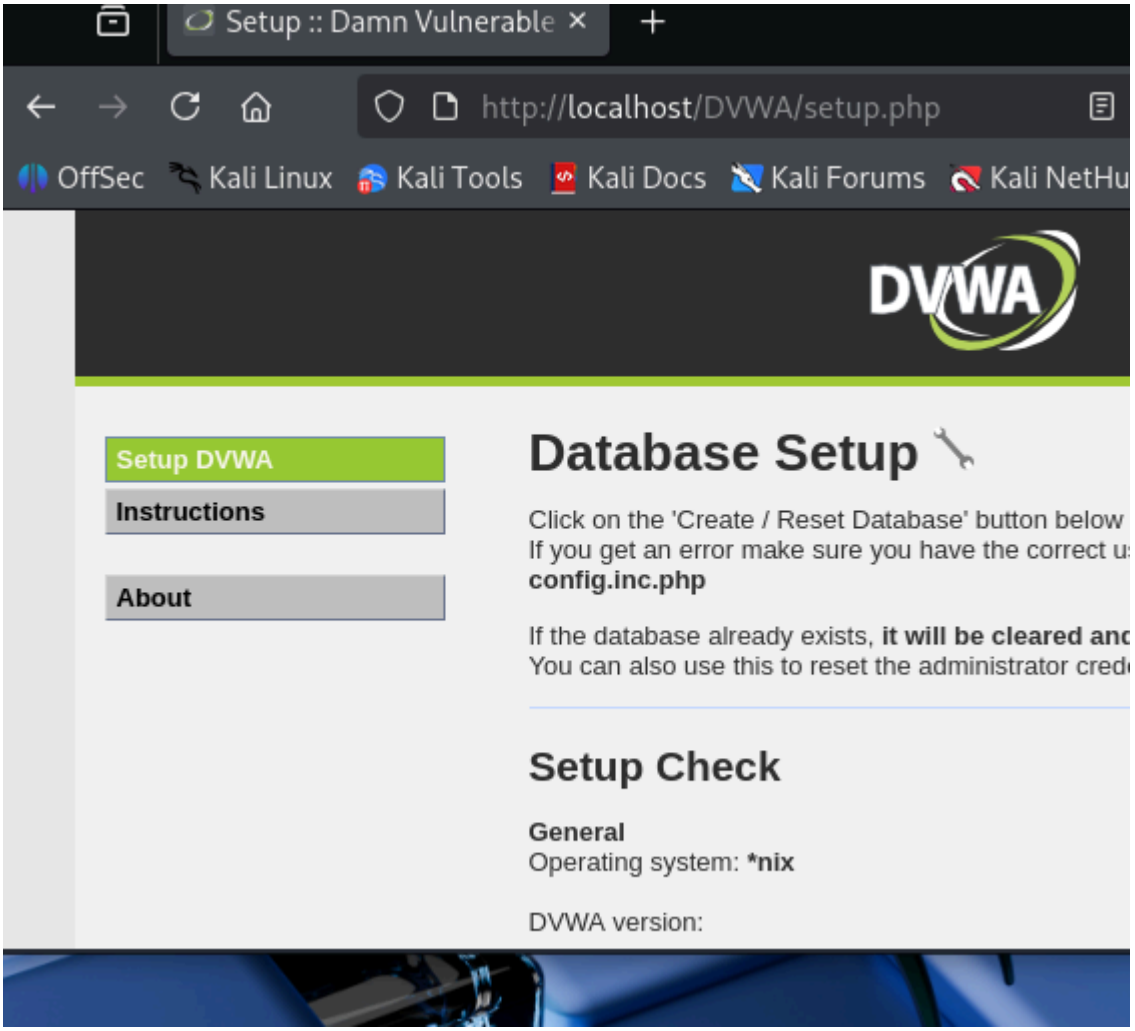
Abre tu navegador y entra en:

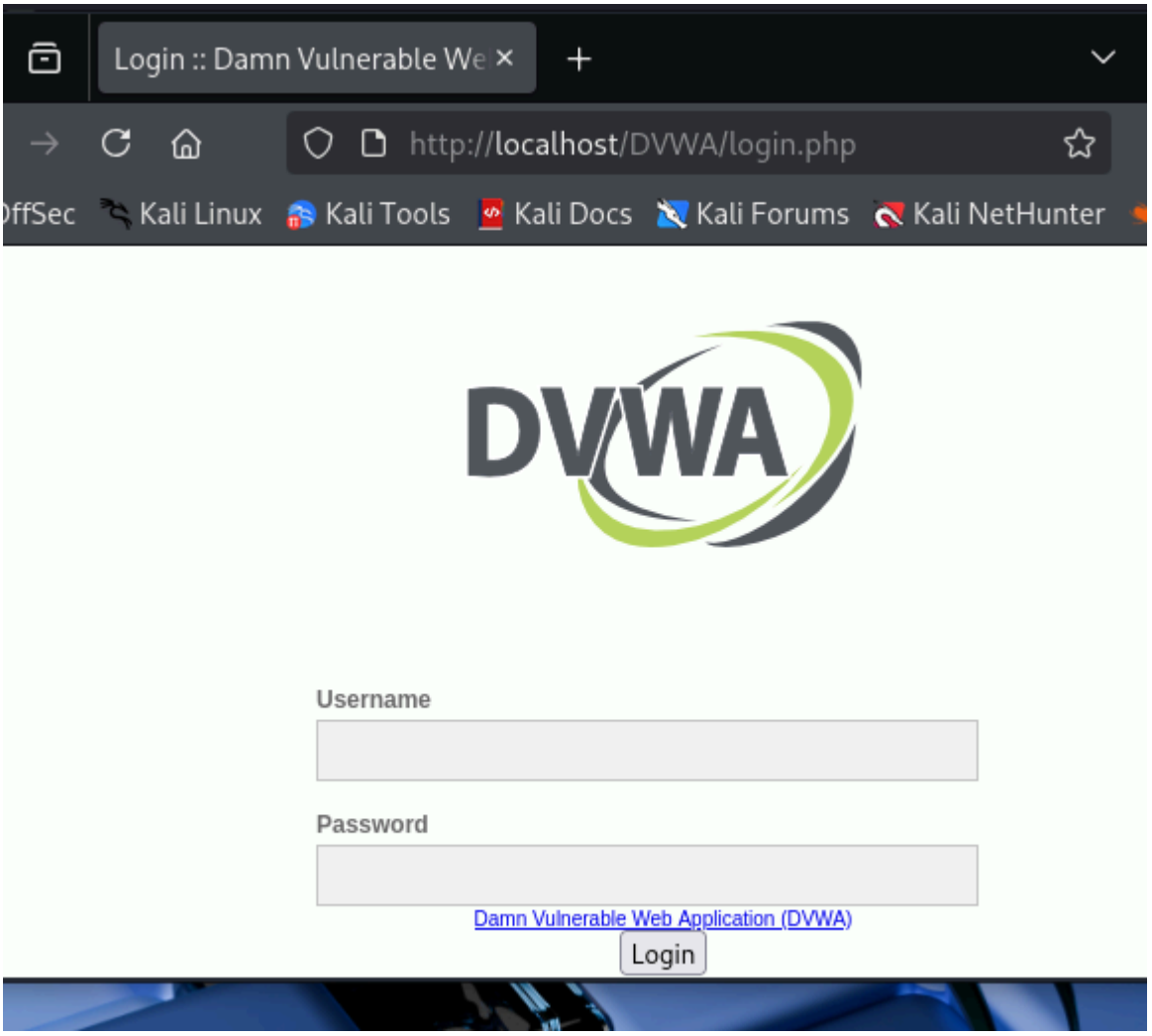
http://localhost/DVWA/setup.php

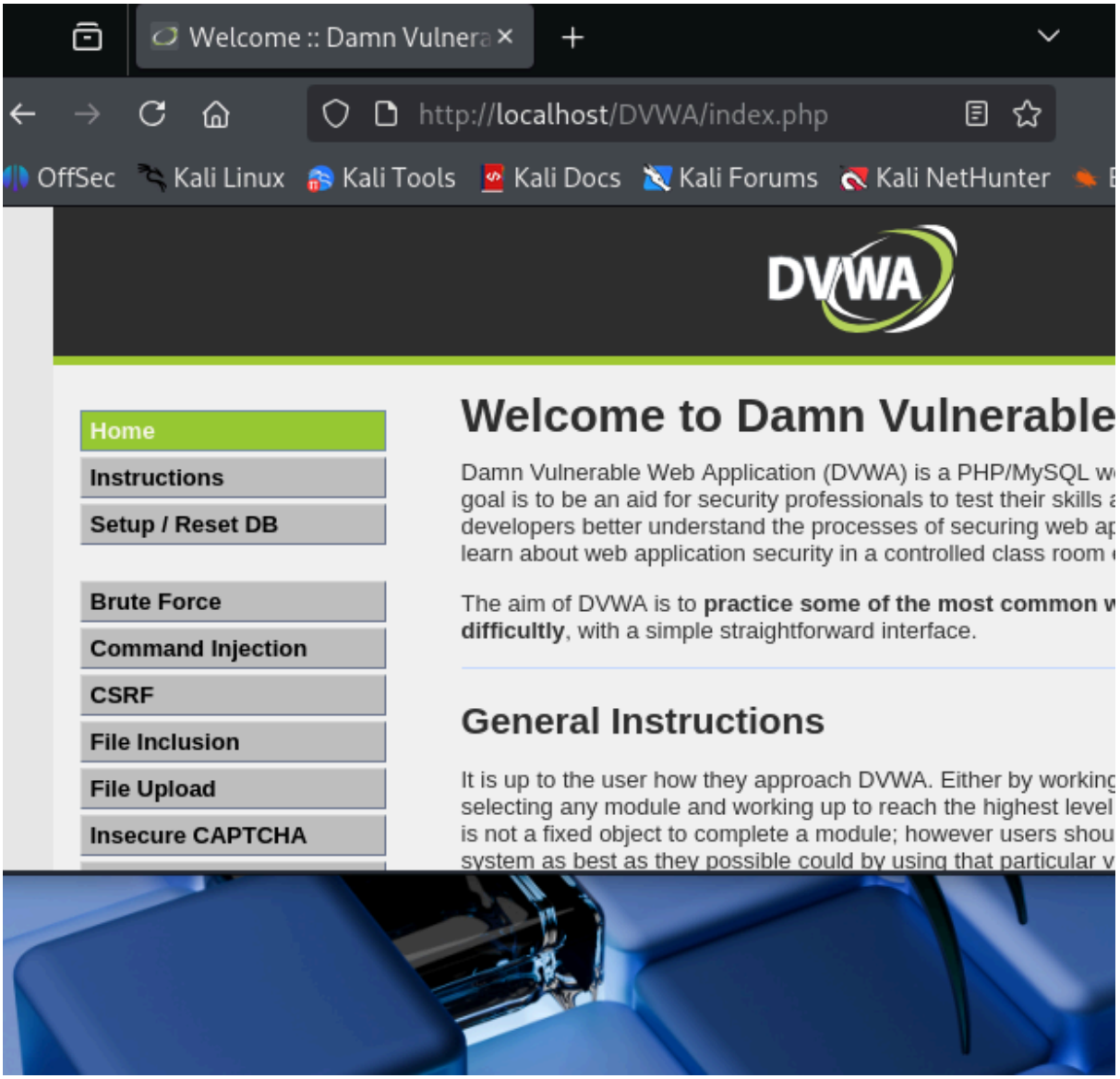
Haz clic en **“Create / Reset Database”**.
Luego entra en:

http://localhost/DVWA/login.php

Usuario: admin
Contraseña: password

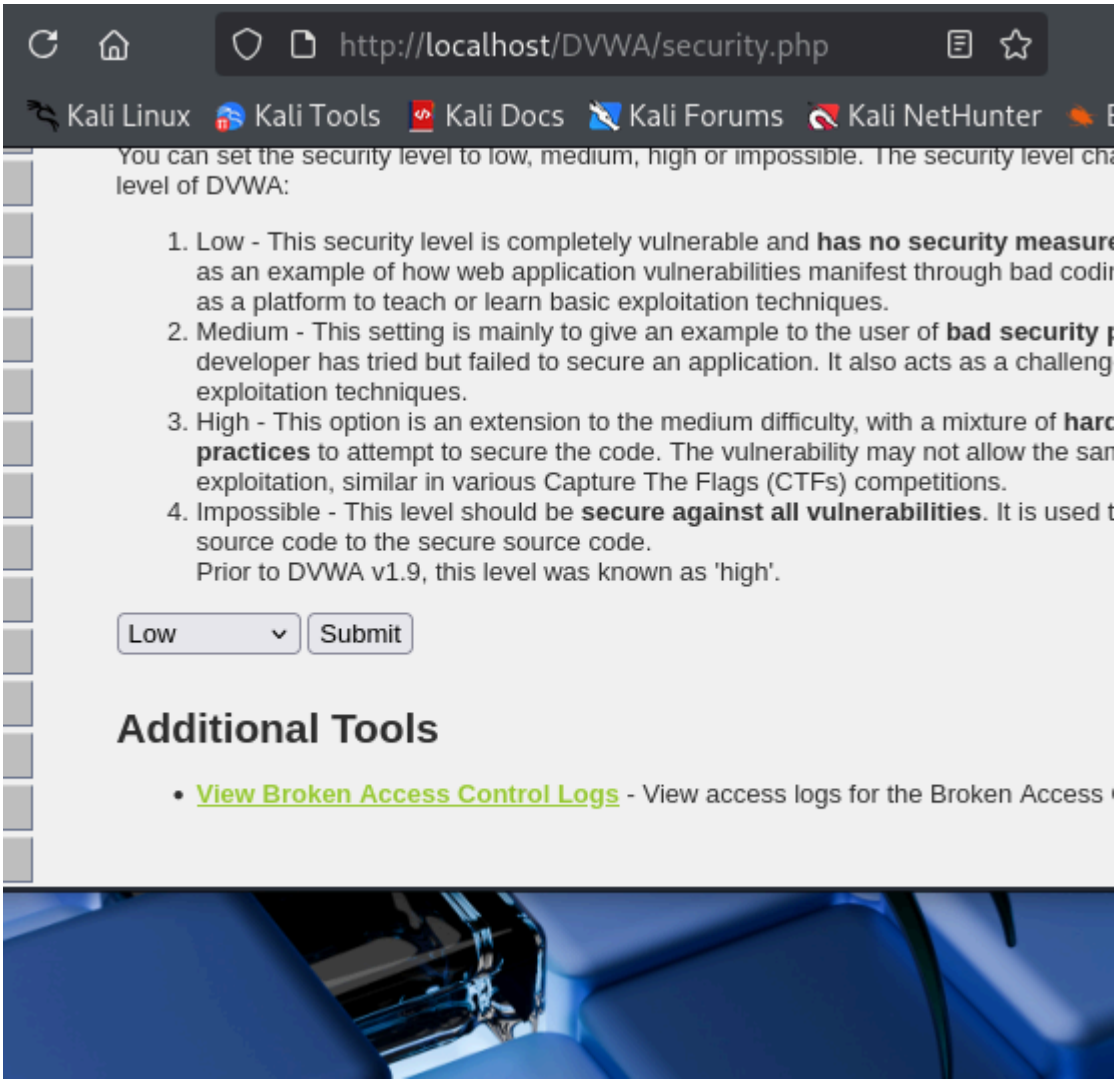

Setup :: Damn Vulnerable
http://localhost/DVWA/setup.php
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHu
DVWA
Setup DVWA
Instructions
About
Database Setup
Click on the 'Create / Reset Database' button below
If you get an error make sure you have the correct u
config.inc.php
If the database already exists, it will be cleared and
You can also use this to reset the administrator cred
Setup Check
General
Operating system: *nix
DVWA version:


Login :: Damn Vulnerable We
http://localhost/DVWA/login.php
ffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
DVWA
Username
Password
Damn Vulnerable Web Application (DVWA)
Login



🔒 3. Configuración de seguridad baja (para prácticas)

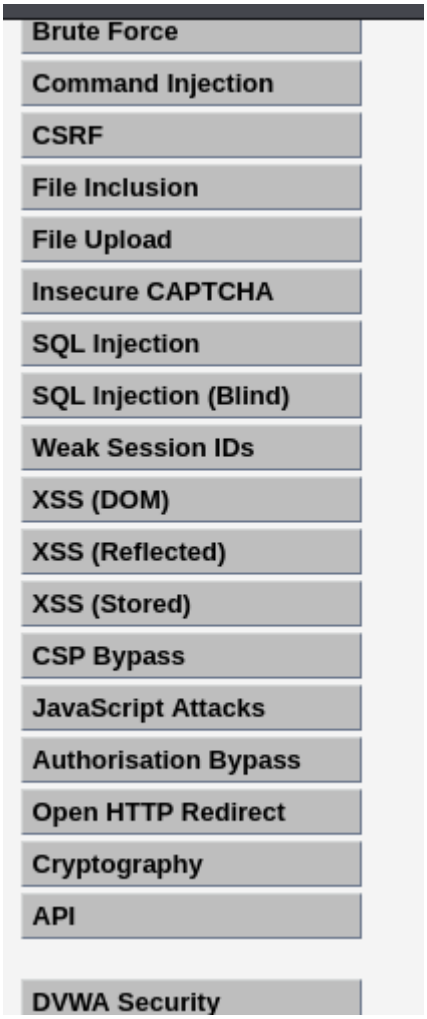
En el menú izquierdo → **DVWA Security** → selecciona **Low**
👉 Esto permite a los alumnos experimentar sin restricciones.



💡 4. Ejercicios propuestos para alumnos de FP

🧩 Nivel básico

1. **Exploración inicial**
   - Acceder a DVWA.



- Navegar por todas las secciones y describir qué tipo de vulnerabilidad trabaja cada una.

Vulnerability: Brute Force

Login

Username:
admin
Password:
••••••••

Login

Welcome to the password protected area admin



More Information

- https://owasp.org/www-community/attacks/Brute_force_attack
- https://www.symantec.com/connect/articles/password-crackers-ensuring-security-you
- https://www.golinuxcloud.com/brute-force-attack-web-forms



Vulnerability: Command Injection

Ping a device

Enter an IP address: Submit

More Information

- https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution
- http://www.ss64.com/bash/
- http://www.ss64.com/nt/
- https://owasp.org/www-community/attacks/Command_Injection

Vulnerability: Command Injection

Ping a device

Enter an IP address: Submit

```
PING localhost (::1) 56 data bytes
64 bytes from localhost (::1): icmp_seq=1 ttl=64 time=0.033 ms
64 bytes from localhost (::1): icmp_seq=2 ttl=64 time=0.042 ms
64 bytes from localhost (::1): icmp_seq=3 ttl=64 time=0.042 ms
64 bytes from localhost (::1): icmp_seq=4 ttl=64 time=0.036 ms

--- localhost ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3082ms
rtt min/avg/max/mdev = 0.033/0.038/0.042/0.004 ms
```

More Information

- https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution
- http://www.ss64.com/bash/
- http://www.ss64.com/nt/
- https://owasp.org/www-community/attacks/Command_Injection

Vulnerability: Cross Site Request Forgery (CSRF)

Change your admin password:

Test Credentials

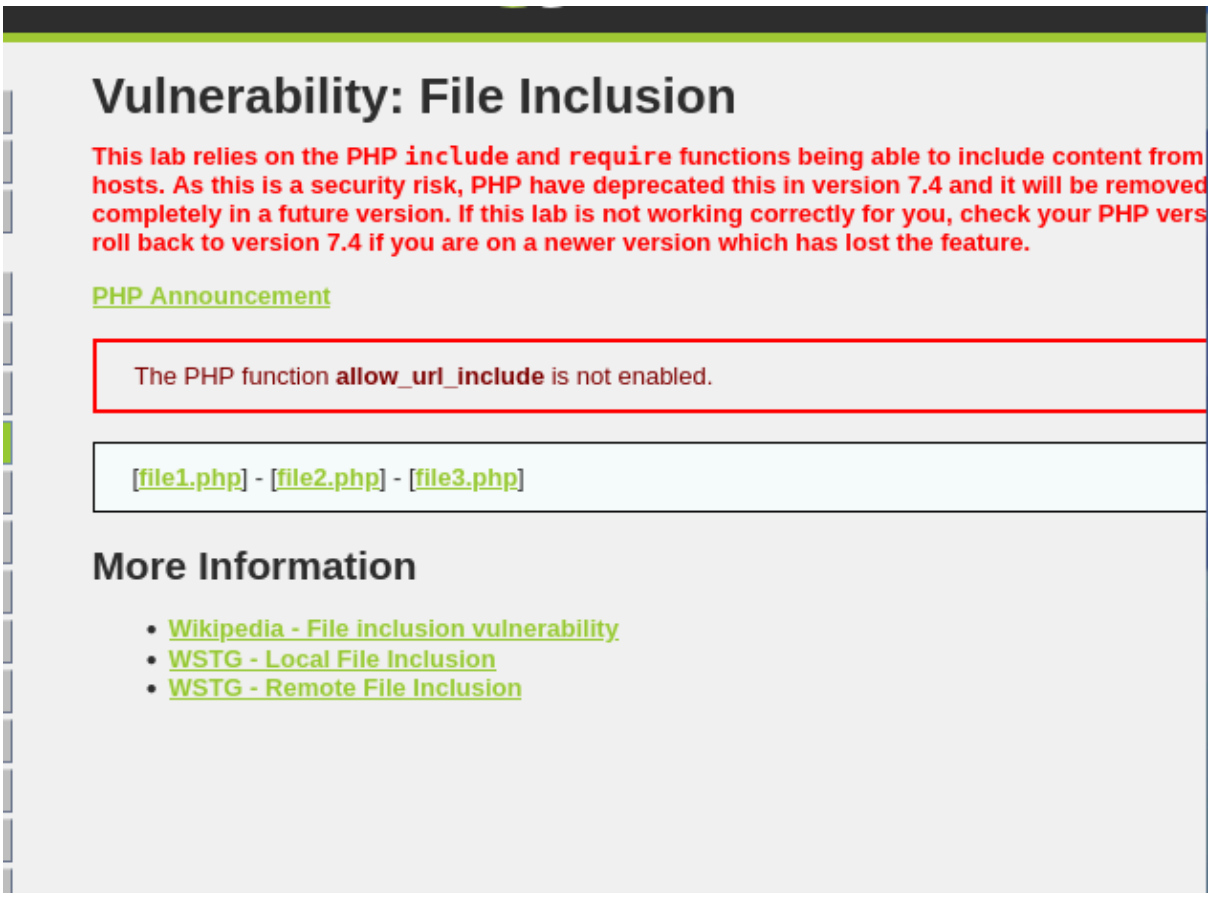
New password:
••••••••
Confirm new password:

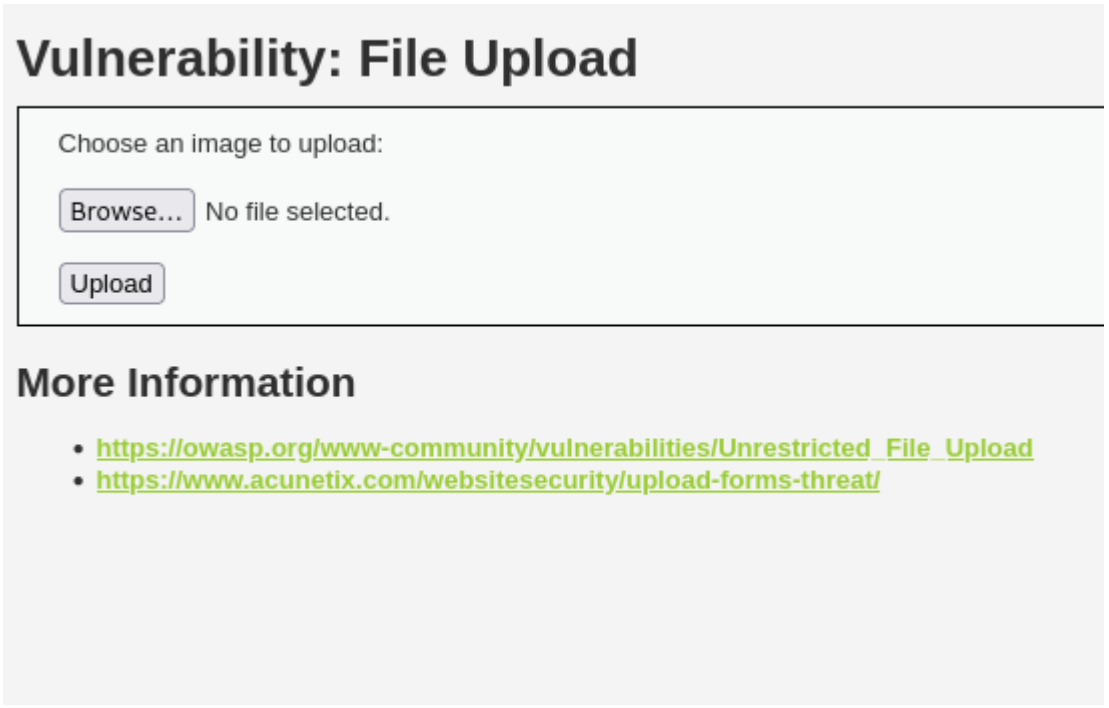
Change

Note: Browsers are starting to default to setting the SameSite cookie flag to Lax, and in doing so are killing of some types of CSRF attacks. When they have completed their mission, this lab will not work as originally expected.

Announcements:

- Chromium
- Edge
- Firefox


Vulnerability: File Inclusion
This lab relies on the PHP include and require functions being able to include content from
hosts. As this is a security risk, PHP have deprecated this in version 7.4 and it will be removed
completely in a future version. If this lab is not working correctly for you, check your PHP vers
roll back to version 7.4 if you are on a newer version which has lost the feature.
PHP Announcement
The PHP function allow_url_include is not enabled.
[file1.php] - [file2.php] - [file3.php]
More Information
Wikipedia - File inclusion vulnerability
WSTG - Local File Inclusion
WSTG - Remote File Inclusion


Vulnerability: File Upload
Choose an image to upload:
Browse...
No file selected.
Upload
More Information
https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
https://www.acunetix.com/websitesecurity/upload-forms-threat/

Vulnerability: Insecure CAPTCHA

reCAPTCHA API key missing from config file: /var/www/html/DVWA/config/config.inc.php

Please register for a key from reCAPTCHA: https://www.google.com/recaptcha/admin/create

More Information

- https://en.wikipedia.org/wiki/CAPTCHA
- https://www.google.com/recaptcha/
- https://owasp.org/www-project-automated-threats-to-web-applications/assets/oats/EN/OAT-009_CAPTCHA_Defeat

Vulnerability: SQL Injection

User ID: Submit

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/
- https://owasp.org/www-community/attacks/SQL_Injection
- https://bobby-tables.com/

Vulnerability: SQL Injection (Blind)

User ID: Submit

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- https://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://owasp.org/www-community/attacks/Blind_SQL_Injection
- https://bobby-tables.com/



Vulnerability: Weak Session IDs

This page will set a new cookie called dvwaSession each time the button is clicked.

Generate

Vulnerability: DOM Based Cross Site Scripting (XSS

Please choose a language:

English Select

More Information

- https://owasp.org/www-community/attacks/xss/
- https://owasp.org/www-community/attacks/DOM_Based_XSS
- https://www.acunetix.com/blog/articles/dom-xss-explained/

DVWA

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name? Submit

More Information

- https://owasp.org/www-community/attacks/xss/
- https://owasp.org/www-community/xss-filter-evasion-cheatsheet
- https://en.wikipedia.org/wiki/Cross-site_scripting
- https://www.cgisecurity.com/xss-faq.html
- https://www.scriptalert1.com/

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

Message *

Sign Guestbook | Clear Guestbook

Name: test
Message: This is a test comment.

More Information

- https://owasp.org/www-community/attacks/xss
- https://owasp.org/www-community/xss-filter-evasion-cheatsheet
- https://en.wikipedia.org/wiki/Cross-site_scripting
- https://www.cgisecurity.com/xss-faq.html
- https://www.scriptalert1.com/

Vulnerability: Content Security Policy (CSP) Bypass

You can include scripts from external sources, examine the Content Security Policy and enter a URL to include here:

Include

As Pastebin and Hastebin have stopped working, here are some scripts that may, or may not help.

- https://digi.ninja/dvwa/alert.js
- https://digi.ninja/dvwa/alert.txt
- https://digi.ninja/dvwa/cookie.js
- https://digi.ninja/dvwa/forced_download.js
- https://digi.ninja/dvwa/wrong_content_type.js

Pretend these are on a server like Pastebin and try to work out why some work and some do not work. Check the help for an explanation if you get stuck.

More Information

- Content Security Policy Reference
- Mozilla Developer Network - CSP: script-src
- Mozilla Security Blog - CSP for the web we have

Vulnerability: JavaScript Attacks

Submit the word "success" to win.

Phrase ChangeMe Submit

More Information

- https://www.w3schools.com/js/
- https://www.youtube.com/watch?v=cs7EQdWO5o0&index=17&list=WL
- https://ponyfoo.com/articles/es6-proxies-in-depth

Module developed by Digininja.

Vulnerability: Authorisation Bypass

This page should only be accessible by the admin user. Your challenge is to gain access to the features u
one of the other users, for example *gordonb* / *abc123*.

Welcome to the user manager, please enjoy updating your user's details.

ID	First Name	Surname	Update
5	Bob	Smith	Update
4	Pablo	Picasso	Update
3	Hack	Me	Update
2	Gordon	Brown	Update
1	admin	admin	Update

Vulnerability: Open HTTP Redirect

Hacker History

Here are two links to some famous hacker quotes, see if you can hack them.

- Quote 1
- Quote 2

More Information

- OWASP Unvalidated Redirects and Forwards Cheat Sheet
- WSTG - Testing for Client-side URL Redirect
- Mitre - CWE-601: URL Redirection to Untrusted Site ('Open Redirect')

Vulnerability: Cryptography Problems

This super secure system will allow you to exchange messages with your friends without anyone else being able to read them. Use the box below to encode and decode messages.

Message:

(•) Encode or ( ) Decode

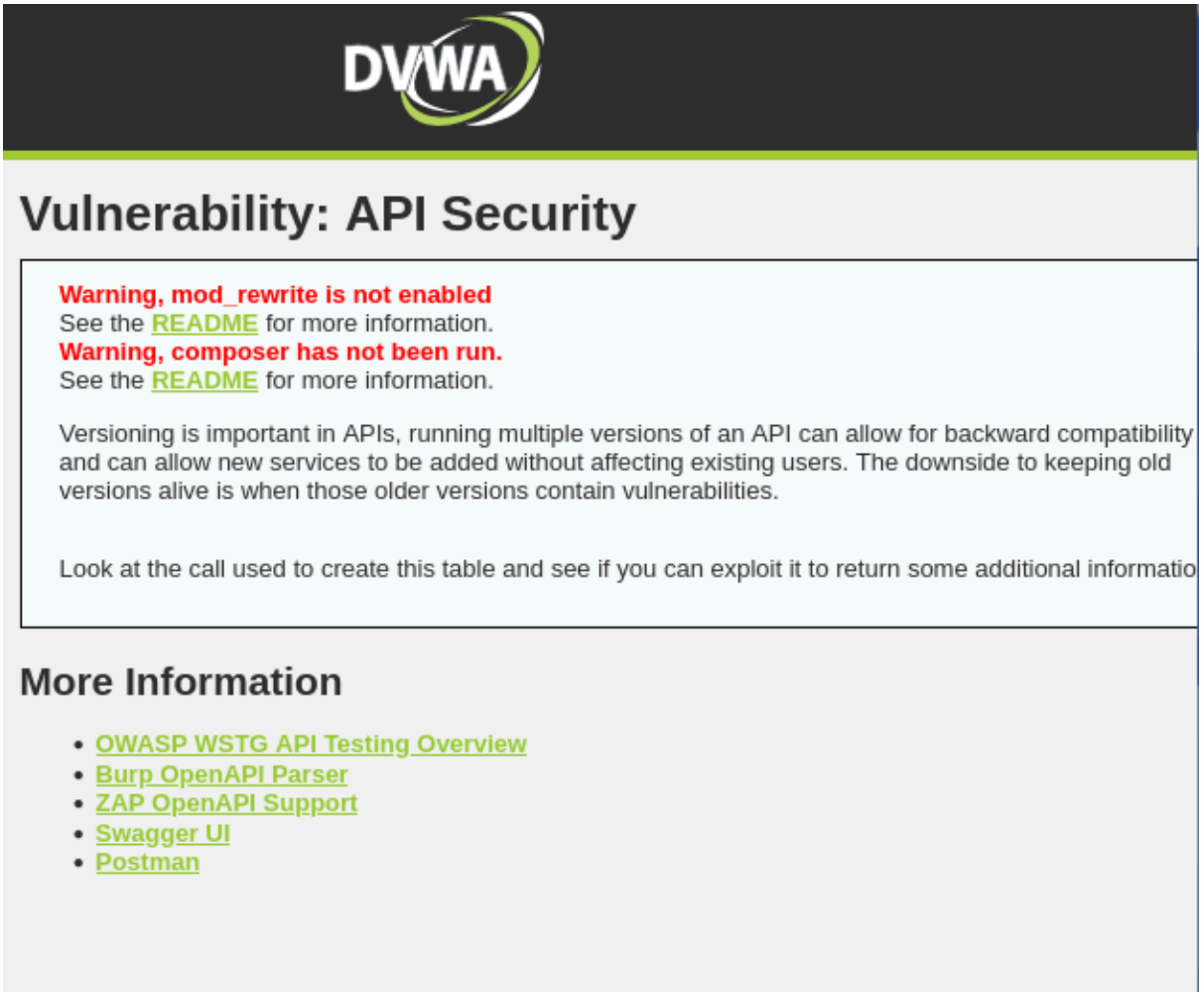
Submit

You have intercepted the following message, decode it and log in below.

Lg4WGlQZChhSFBYSEB8bBQtPGxdNQSwEHREOAQY=

Password:
••••••••

Login

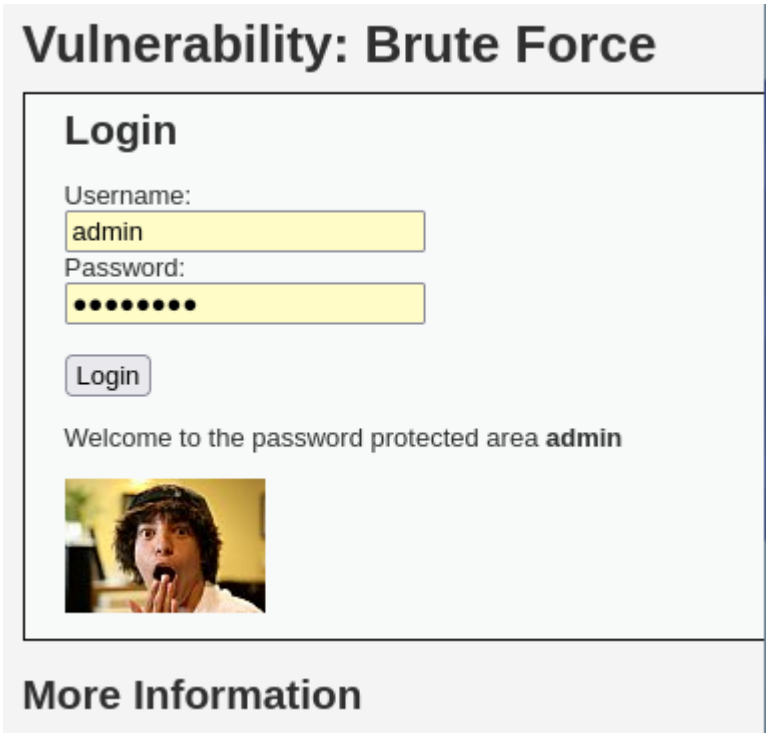


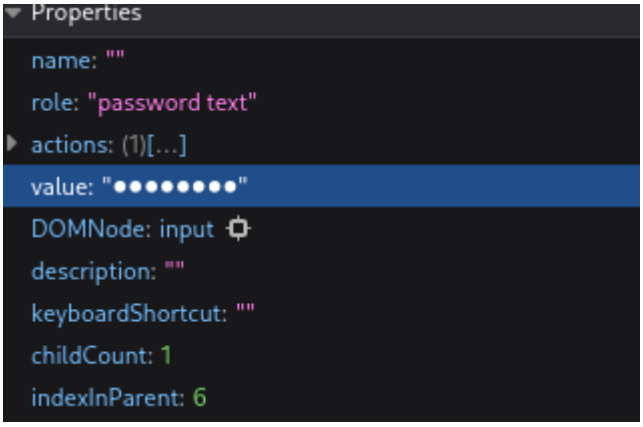
Brute Force	**Fuerza Bruta (Brute Force)**	Permite probar ataques de adivinación de contraseñas contra un formulario de inicio de sesión.
Command Injection	**Inyección de Comandos (Command Injection)**	Permite ejecutar comandos del sistema operativo en el servidor a través de entradas de usuario no validadas.
CSRF	**Falsificación de Solicitud en Sitios Cruzados (Cross-Site Request Forgery)**	Permite realizar acciones no autorizadas en nombre de un usuario autenticado sin su conocimiento.

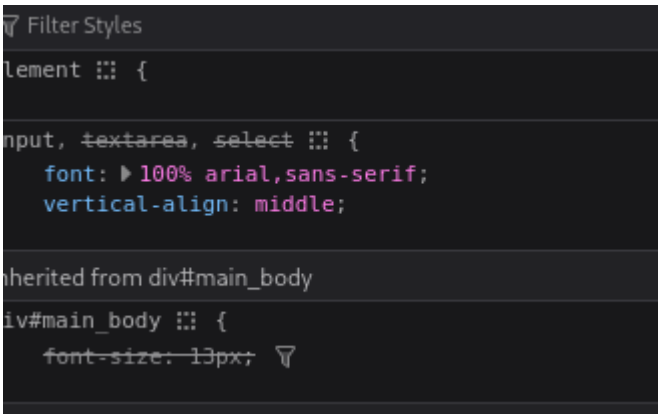
File Inclusion	**Inclusión de Archivos (File Inclusion - LFI/RFI)**	Permite incluir archivos locales (LFI) o remotos (RFI) en la aplicación, lo que puede llevar a la divulgación de información o a la ejecución remota de código.
File Upload	**Carga de Archivos Insegura (Unrestricted File Upload)**	Permite subir archivos potencialmente peligrosos o maliciosos (como *scripts* de *shell*) al servidor, lo que puede llevar a la ejecución de código.
SQL Injection	**Inyección SQL (SQL Injection)**	Permite inyectar código SQL malicioso para manipular o acceder a datos de la base de datos sin autorización.
SQL Injection (Blind)	**Inyección SQL Ciega (Blind SQL Injection)**	Una forma de inyección SQL donde la aplicación no devuelve datos directamente, obligando al atacante a inferir la información mediante respuestas booleanas o basadas en tiempo.
XSS (Reflected)	**Cross-Site Scripting Reflejado (Reflected XSS)**	El *script* malicioso se inyecta a través de la entrada del usuario (por ejemplo, en un parámetro URL) y se "refleja" de vuelta al navegador de la víctima.
XSS (Stored)	**Cross-Site Scripting Almacenado (Stored XSS)**	El *script* malicioso se almacena permanentemente en la aplicación (por ejemplo, en una base de datos) y se sirve a otros usuarios cuando visitan la página.
XSS (DOM)	**Cross-Site Scripting basado en DOM (DOM-based XSS)**	La vulnerabilidad existe en el código del lado del cliente donde se manipula el Document Object Model (DOM) con datos inyectados por el usuario.

- Cambiar el nivel de seguridad y observar las diferencias en el código fuente (con “Inspeccionar elemento”).

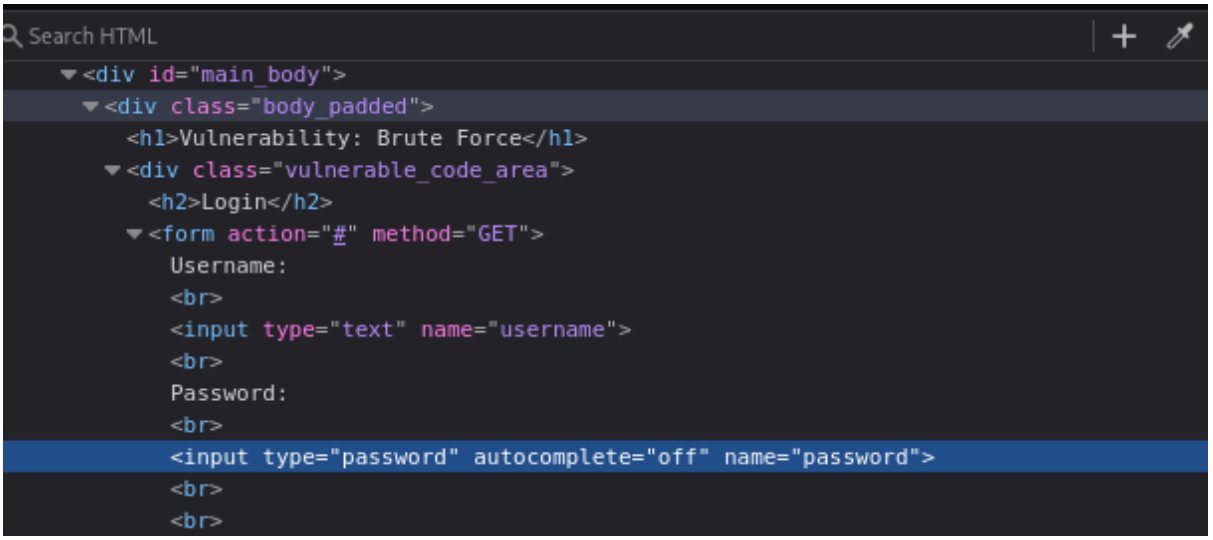
CON NIVEL DE SEGURIDAD IMPOSIBLE



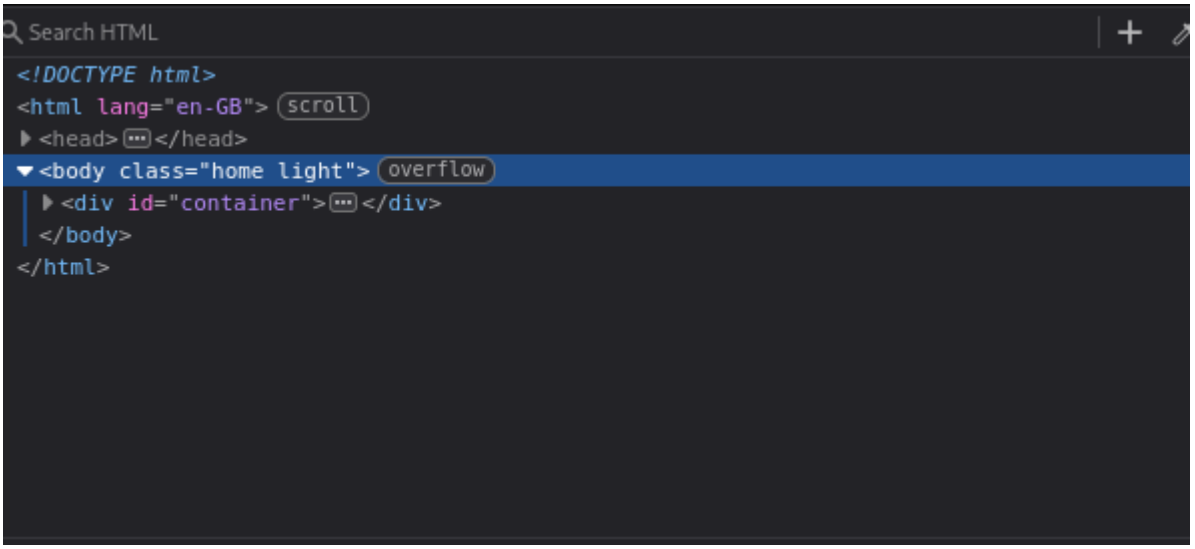




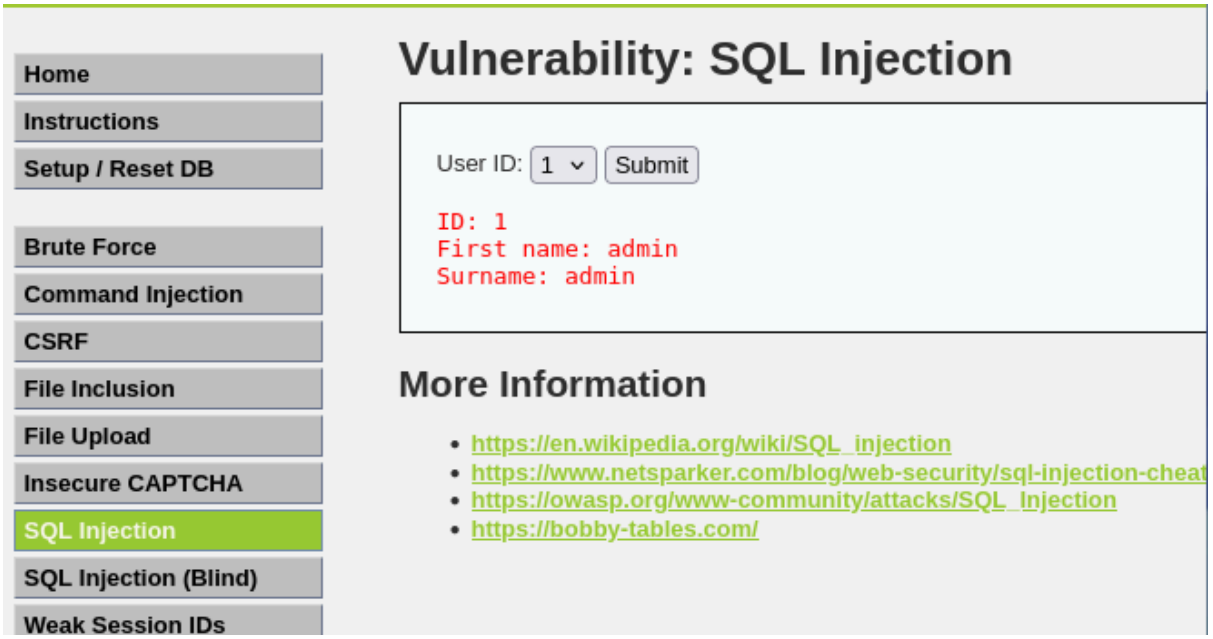
SCREEN OF THE LOW SECURITY



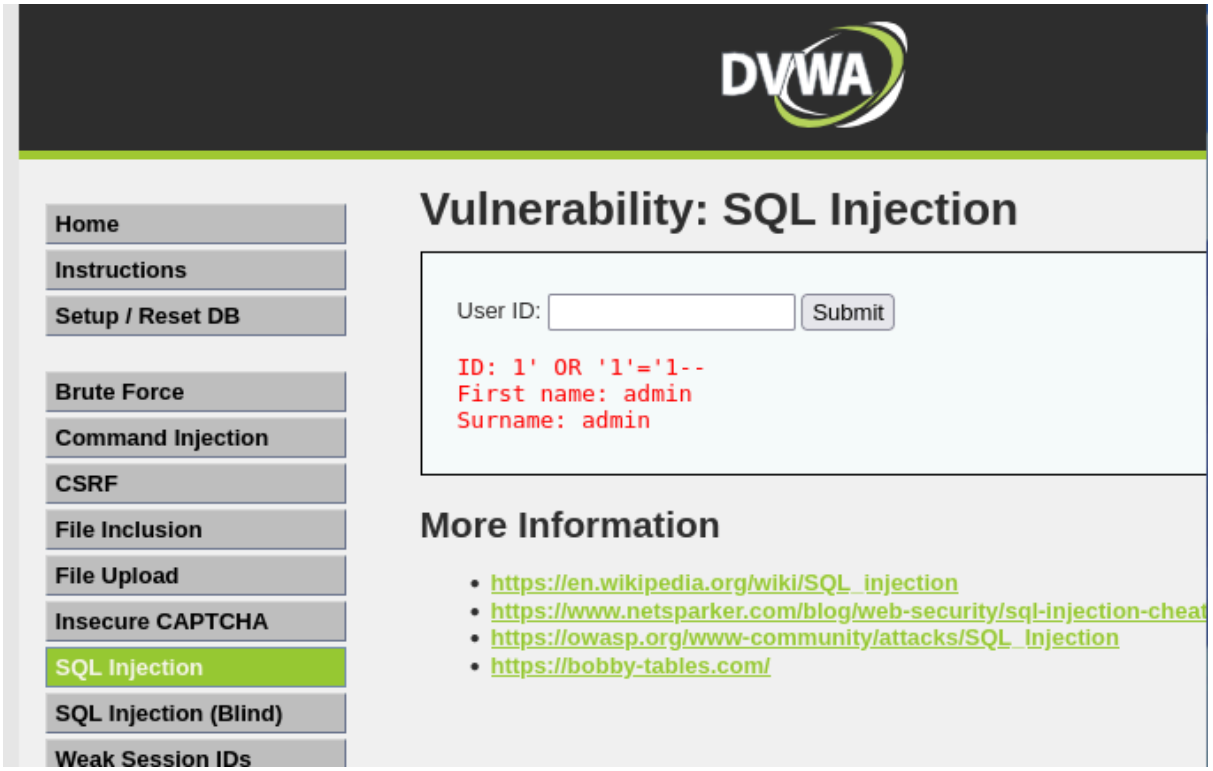
SCREEN OF THE MEDIUM SECURITY



2. **Login de fuerza bruta**
    - Utilizar **Burp Suite** o **Hydra** para probar un ataque de fuerza bruta en la sección *Brute Force*.
    - Objetivo: obtener las credenciales válidas.
3. **Inyección SQL básica**
    - En el módulo *SQL Injection*, obtener el nombre del usuario 1 con una consulta maliciosa.



- Ejemplo de entrada:
- 1' OR '1'='1 --



4. **Cross-Site Scripting (XSS)**
   - Insertar un script simple que muestre un alert.
   - <script>alert('XSS ejecutado!')</script>
   - Explicar qué implicaciones tiene esto si se hiciera en una web real.

🧰 **Nivel intermedio**

5. **Command Injection**
    - Ejecutar un comando del sistema operativo (por ejemplo, ls o cat /etc/passwd).
    - Analizar cómo DVWA no valida correctamente el input.
6. **File Upload**
    - Subir un archivo PHP malicioso (web shell).
    - Observar qué ocurre si se sube con nivel de seguridad “Low” vs “Medium”.
7. **CSRF (Cross-Site Request Forgery)**
    - Modificar la contraseña del administrador desde otro formulario forzado.

🧠 **Nivel avanzado**

8. **Mitigación**
    - Cambiar el nivel de seguridad a “High”.
    - Analizar cómo se han corregido las vulnerabilidades en el código PHP.
    - Proponer buenas prácticas para evitar inyección SQL y XSS.
9. **Registro de auditoría**
    - Instalar apache2-utils y usar tail -f /var/log/apache2/access.log para ver qué peticiones realiza el ataque.
10. **Informe final**

- Cada alumno redacta un informe con:
    - Vulnerabilidades detectadas.
    - Pruebas realizadas.
    - Riesgos.
    - Propuestas de mitigación.

🧠 **5. Extensión (opcional)**

Puedes conectar **DVWA con OWASP ZAP o Burp Suite** y pedir a los alumnos que:

- Ejecuten un escaneo automatizado.
- Interpreten los resultados.
- Clasifiquen las vulnerabilidades según su nivel de riesgo (bajo, medio, alto).

Problemas en el caso de que no funcione mysql

Problemas con mysql

1. Comprobar si el servicio está activo

Comprueba estado para MariaDB (habitual en Debian/Kali)

sudo systemctl status mariadb

o para MySQL (si usas mysql-server)

sudo systemctl status mysql

Si ves inactive/failed o not found, sigue al paso 2. Si está active (running) y sigue el error, ve al paso 4.

---

2. Iniciar (o reiniciar) el servicio

Para MariaDB

sudo systemctl start mariadb

sudo systemctl enable mariadb

O para MySQL

sudo systemctl start mysql

sudo systemctl enable mysql

2º problemas al crear la base de datos dentro del laboratorio dvwa

Abre el fichero:

sudo nano /var/www/html/DVWA/config/config.inc.php

Debe tener:

$_DVWA['db_server']   = '127.0.0.1';

$_DVWA['db_database'] = 'dvwa';

$_DVWA['db_user']   = 'dvwauser';

$_DVWA['db_password'] = 'dvwapass';

$_DVWA['recaptcha_public_key'] = '';

$_DVWA['recaptcha_private_key'] = '';

En el fichero tiene que aparecer

```
$_DVWA = array();
$_DVWA[ 'db_server' ]   = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA[ 'db_user' ]  = getenv('DB_USER') ?: 'dvwauser';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ?: 'dvwapass';
$_DVWA[ 'db_port']    = getenv('DB_PORT') ?: '3306';
```

```
sudo apt install php-mysqli php-gd php-curl php-zip php-xml -y
```

```
sudo systemctl restart apache2
```